

PQ v1.9.1 · GPL-3.0 · Python / Flask

PQC-Monitor

Post-Quantum Cryptography readiness monitoring for sector-wide
TLS estates

Executive & technical briefing — Security Leadership

Quantum computers can't break this deck yet. We checked.

WHY NOW

The Quantum Deadline

2030

RSA & ECC **deprecated** for US federal use

NIST IR 8547 transition timeline

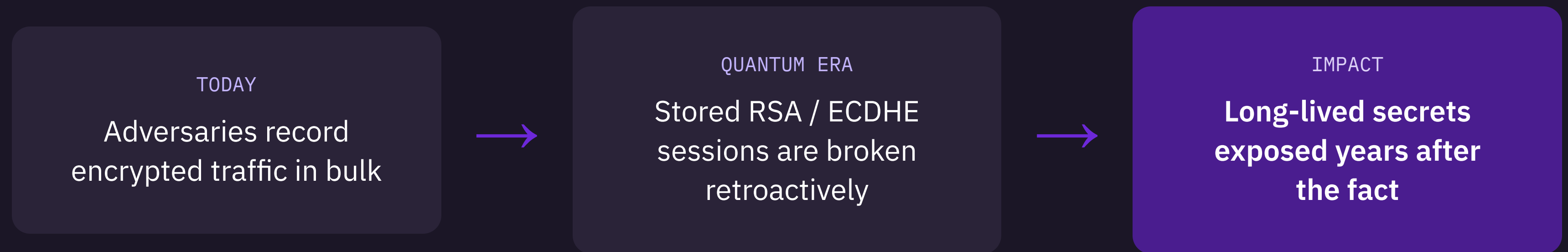
2035

Classical public-key crypto **disallowed**

ML-KEM / ML-DSA become the baseline

Sector-wide migrations take years. Knowing **where every domain stands today** is the prerequisite for finishing on time.

Harvest Now, Decrypt Later



Any data whose confidentiality must survive past ~2035 — health records, financial data, state communications — is **already at risk** when it crosses classical TLS.

Somewhere, a data centre is very patiently hoarding your handshakes.

WHAT IT DOES

Capabilities Overview

01 · DISCOVER

TLS & certificate discovery

Ports, STARTTLS mail, chains, ciphers, CDN, DNS enumeration

02 · SCORE

Multi-guideline scoring

NIST SP 800-131Ar3, BSI TR-02102-1, CCN-STIC-221

03 · WATCH

CT log monitoring

Detects PQC certificate deployments as they appear

04 · PLAN

Migration roadmaps

Phased action plans generated per domain estate

05 · TRACK

Scheduled trend tracking

Periodic re-scans; score and adoption over time

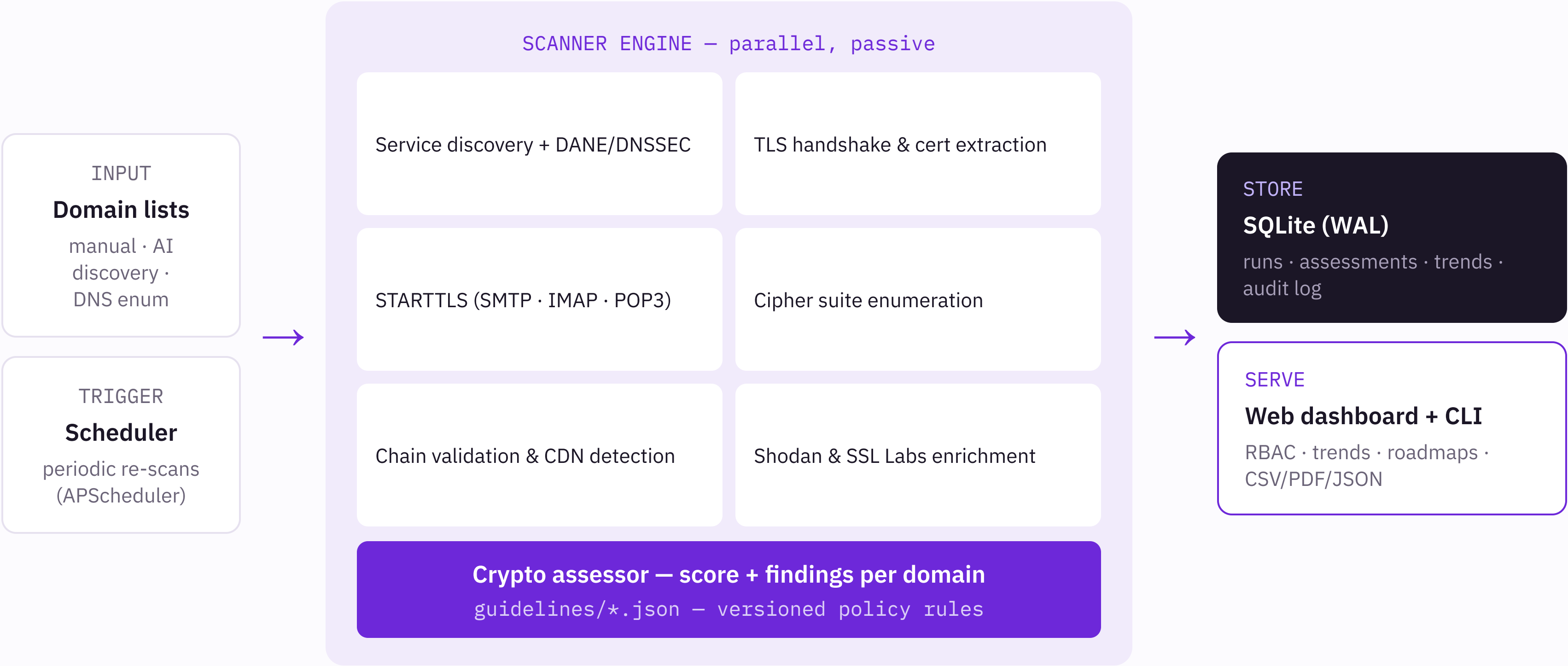
06 · SHARE

Role-scoped reporting

Group reports by community, region, country — CSV / PDF

● **Strictly passive** — no exploit payloads, no DoS, authorised targets only.

System Architecture



The Assessment Pipeline

1 · DISCOVER

Open TLS ports, mail STARTTLS,
DANE records

2 · PROBE

Handshake per port; extract certificates &
key exchange

3 · ENUMERATE

Full accepted cipher set, chain analysis,
CDN fingerprint

4 · NORMALISE

Raw scan → CryptoFacts; OpenSSL names
→ IANA

5 · ASSESS

Score 0–100 against each guideline;
named findings

6 · PERSIST

Assessment + enrichment blobs stored
per run

Re-assessment without re-scanning: when a guideline updates, stored scan data is replayed through the new rules — zero network traffic.

Readiness Scoring

● Critical	0 – 25	Broken or deprecated crypto in use — RC4, DES, MD5, SHA-1 certs, RSA-1024
● Weak	26 – 50	Below recommended minimums; no PQC
● Moderate	51 – 75	Good classical crypto — TLS 1.3, ECDHE, SHA-256 — but no PQC yet
● Ready	76 – 100	PQC detected — ML-KEM key exchange or ML-DSA certificates — or transition complete
● N/A	—	No reachable TLS service — excluded from averages and roadmaps

Regulatory Guidelines

NIST

SP 800-131Ar3

US federal algorithm transitions — Oct 2024 draft, incl. PQC timeline

BSI

TR-02102-1 (2026)

German federal cryptographic requirements and key-length recommendations

CCN

STIC-221 (2023)

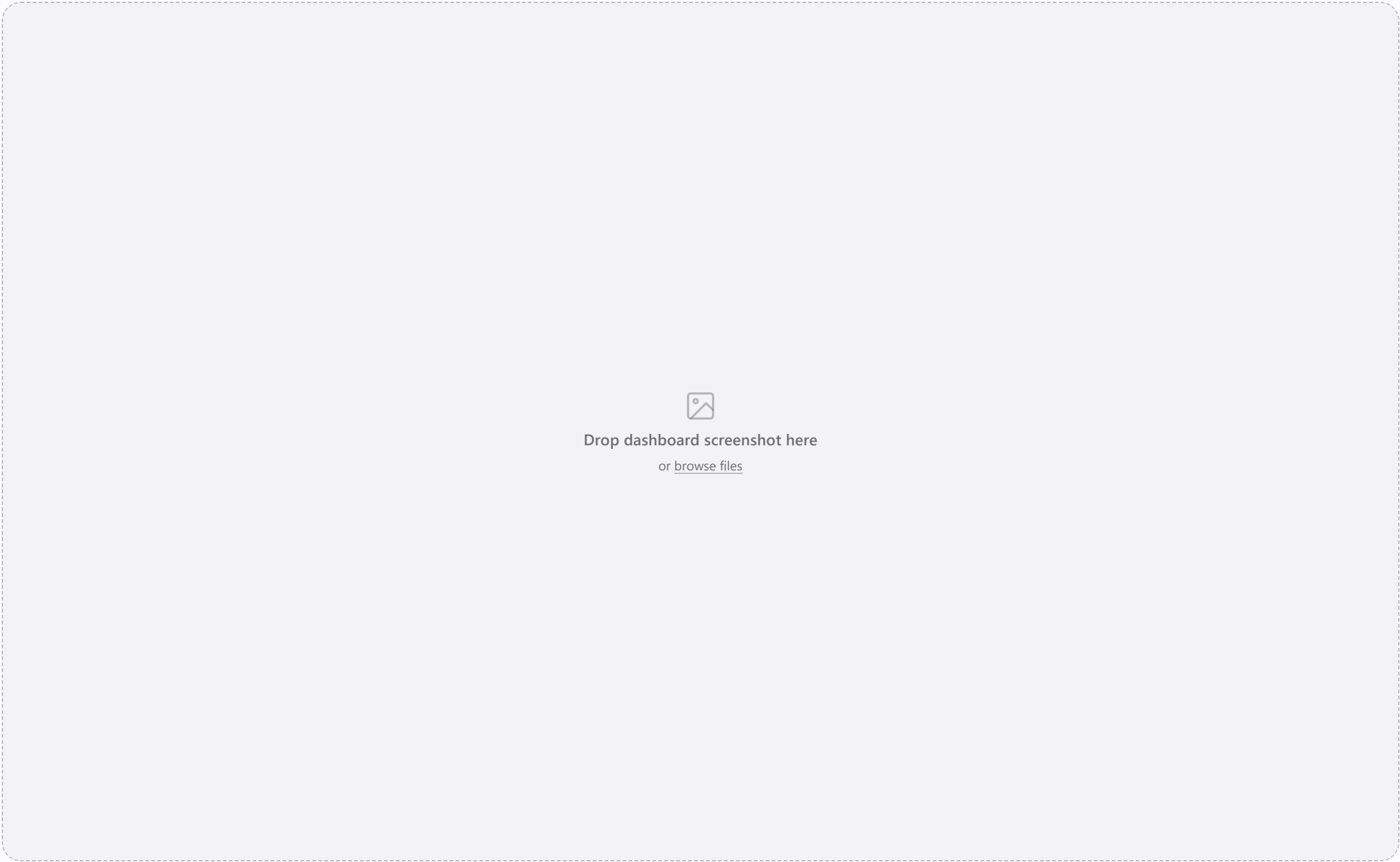
Spanish national cryptography guidance for public-sector systems



Each guideline is a **versioned JSON rule file** — update the rules, re-assess every stored scan, no rescanning required.

THE PRODUCT

The Dashboard



01	Dashboard	summary, distribution, coverage
02	Group Report	community · region · country
03	Scan & Discovery	manual runs, AI domain lists
04	Trends	score & PQC adoption over time
05	CT Monitor	PQC certs in the wild
06	Roadmap	phased migration plans
07	Full TLS detail	every cipher + SSL Labs grade

Roles & Communities

Admin

Runs scans, manages users, lists, organisations and communities. Sees everything. Full audit log.

Community Manager

Aggregate group reports for assigned communities — by community, region or country. CSV / PDF export.

Analyst

Read-only view of assigned domain lists only — assessments, trends, CT results, roadmaps.

Built for **multi-organisation communities**: a sector CERT can host one instance, scope each member to its own estate, and publish shared progress reports.

The Migration Loop



Group reports make progress **comparable across member organisations** — a measurable programme, not a one-off audit.

STATUS

Project Maturity

1.9.1

current release — 15
versions since 1.0

340+

unit tests across scanner,
scoring, RBAC

12

CLI commands + full
REST API

17

schema versions,
automatic migrations

In production

systemd services · Gunicorn · nginx TLS termination · scheduled
scans on live estates

Open source, AI-assisted

GPL-3.0 · built with Claude, every line human-reviewed

15 releases, and only one of them was fixing what the previous one broke. Per release.

WHAT'S NEXT

Development Roadmap

NEAR TERM

- Executive PDF reporting
- Certificate-expiry warnings
- Roadmap export (PDF / DOCX)
- Asset criticality weighting

MID TERM

- Geographic map view (choropleth)
- Sector benchmarking
- Budget estimation in roadmaps
- Service-type UI filtering

LONG TERM

- SAML / OIDC authentication
- Trend alerting (email / webhook)
- Multi-resource domain model
- Frontend separation

Delivered from this backlog already: SSL Labs integration, DNS deep-enumeration, community reporting, country analytics.

SUMMARY

Key Takeaways

- 1 The PQC migration has a regulatory deadline — and the clock runs on **data recorded today**.
- 2 PQC-Monitor gives a sector **one shared, evidence-based picture** of where every domain stands.
- 3 It turns migration into a **measurable loop**: scan, score, plan, fix, prove progress.

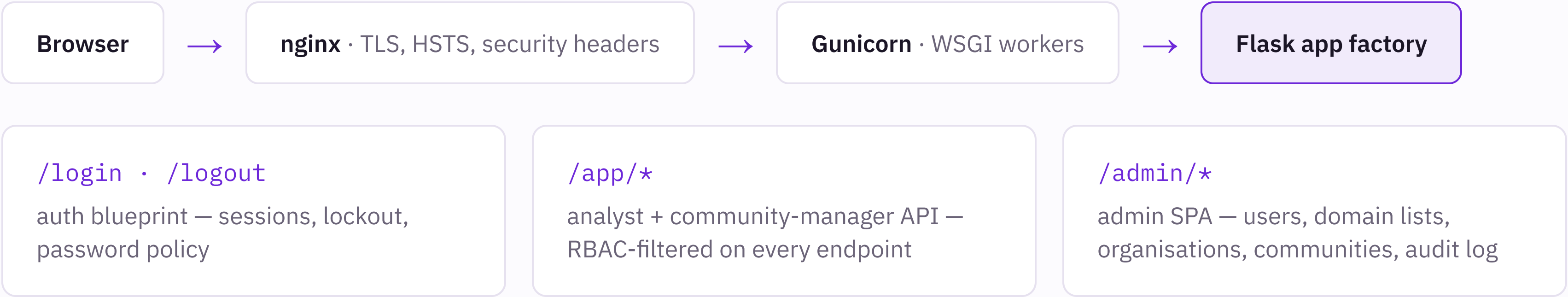
Annex follows — architecture, schema, API, deployment and scoring internals.

ANNEX

Technical Detail

Architecture · scanner modules · database schema · API surface · deployment · DNS enumeration · security · scoring internals

Architecture Detail



Two independent systemd services — web (Gunicorn) and scheduler (APScheduler) — under one target. A scheduled scan never blocks a user request.

Scanner Modules

service_discovery	TCP-connect ports + DANE/DNSSEC	tls_probe	handshake & certificate extraction
starttls_probe	SMTP/IMAP/POP3 upgrade, by protocol family	cipher_enum	active suite enumeration incl. CAMELLIA/SEED
chain_validator	full certificate chain analysis	cdn_detector	Cloudflare, Fastly, Akamai fingerprints
dns_enumerator	CT SANs · wordlist · DNSDumpster · passive	crypto_extractor	raw scan → normalised CryptoFacts
crypto_assessor	multi-guideline scoring engine	shodan_client	optional passive enrichment
ssllabs_client	API v4 — cache-only in scans, display-only grade	orchestrator	parallel coordination of all of the above

Database Schema

scan_runs · assessments

One row per run; one assessment per domain per run — score, level, findings, ciphers, PQC flag, cert expiry

domain_extra · tls_results

Keyed enrichment blobs — cipher_enum, chain, cdn, dns_enum, shodan, sslabs — plus raw per-port probe results

organisations · communities

Org grouping with country/region; communities aggregate orgs for scoped group reporting (v17)

users · user_domain_lists

RBAC tables — roles, domain-list and organisation assignments, community membership

ct_summaries · roadmaps

Certificate Transparency query results and saved migration roadmaps

audit_log

Every login, data access and scan initiation — immutable trail

SQLite · WAL mode — single file, zero ops

schema v17 — incremental migrations on startup

newest-per-domain — dashboard semantics

API Surface

Assessments & trends — all roles, scoped

GET /api/summary · /api/assessments
GET /api/domain/<domain> · /api/runs
filters: run · org · region · country · service_type

Group reports — community manager +

GET /api/communities/<id>/report[.csv|.pdf]
GET /api/regions/<name>/report[.csv|.pdf]
GET /api/countries/<cc>/report[.csv|.pdf]

Scanning & discovery — admin only

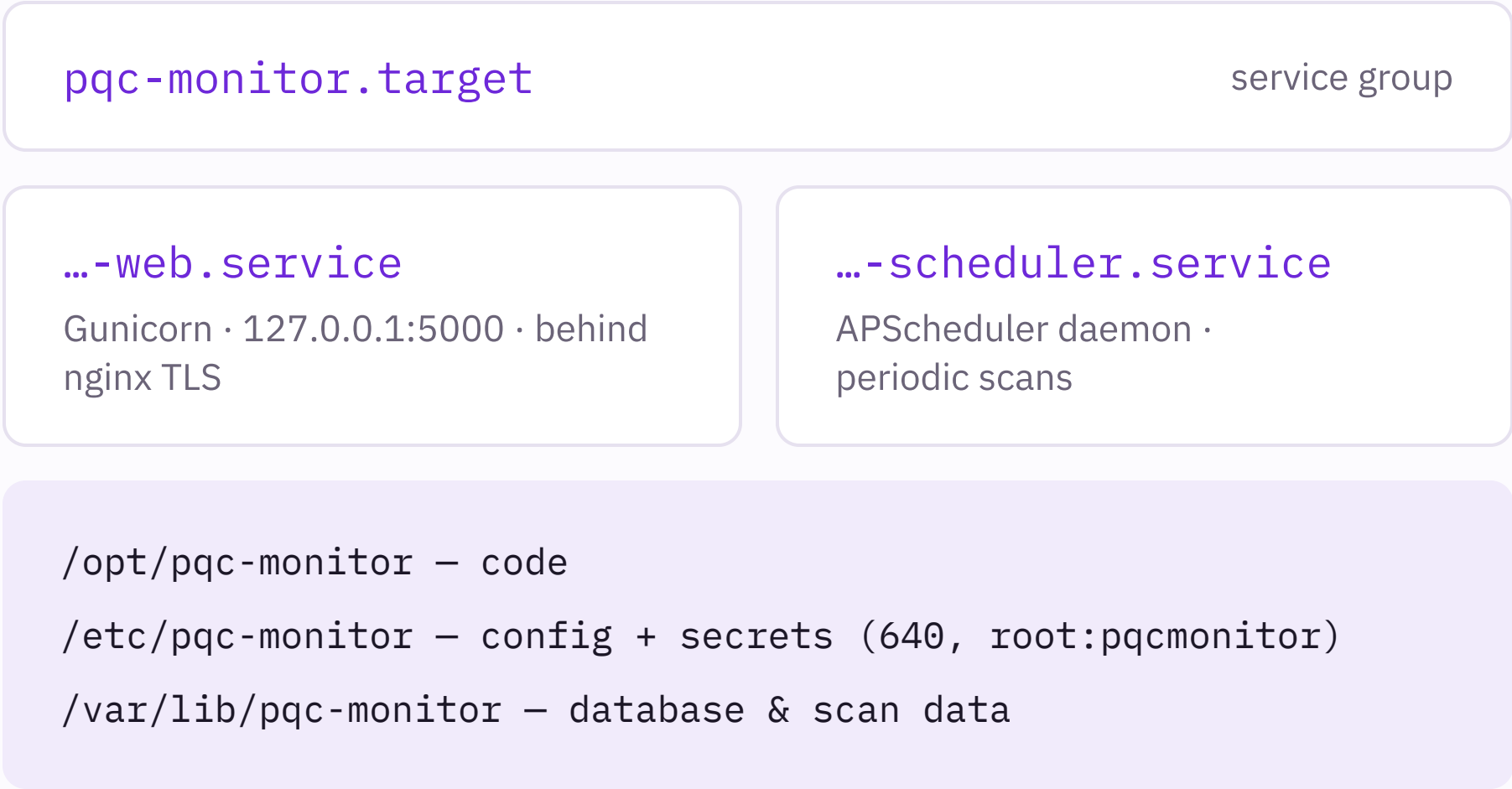
POST /api/scan · /api/reassess
POST /api/discover · /api/dns-enumerate
GET/POST /api/ssllabs/<domain>[/refresh]

Administration — admin only

/admin/* — users, domain lists,
organisations, communities, audit log
CRUD /api/organisations

Every endpoint is authenticated; every domain-data response passes `filter_assessments()`; every group report passes org-scoping.

Deployment Topology



Minimal footprint — runs comfortably on a 1-vCPU cloud micro instance

Non-privileged — dedicated pqcmonitor system user, no root at runtime

One-command install — `install.sh --production` preserves config & DB on update

Incremental deploys — `deploy.sh` syncs changed files, restarts only affected services

DNS Enumeration

- | | |
|----------------------|--|
| 1 · direct DNS | A, AAAA, MX, NS, CNAME, TXT (SPF / DMARC) — normalised MX handling |
| 2 · CT SANs | crt.sh — subdomains revealed by issued certificates |
| 3 · wordlist | ~120 common prefixes resolved concurrently |
| 4 · DNSDumpster | official REST API — session-level quota detection, fails soft |
| 5 · passive fallback | SRV probing (20 service prefixes) · AXFR attempts per NS · PTR reverse lookups — activates automatically when DNSDumpster is exhausted or unconfigured |

Security & RBAC

Session security

- HMAC-signed cookies · HttpOnly · SameSite · Secure
- 8-hour session lifetime
- 10 failed logins → 15-minute lockout
- Per-IP login rate limiting

Access control

- Permission strings checked per endpoint
- Domain-list scoping for analysts
- Org-union scoping for community managers
- Full audit log — logins, data access, scans

| Pluggable AuthProvider interface — SAML / OIDC can be added **without changing any route code.**

Scoring Engine Internals

NORMALISATION

All cipher names normalised OpenSSL → IANA before rule matching, so guideline recommended/deprecated lists match exactly. Full enumerated suite set merged into each assessment.

NAMED FINDINGS

Every finding names the specific suites to remove — machine-readable cipher lists per finding, directly actionable by server admins.

N/A SEMANTICS

A host where no TLS handshake completes is scored n/a — never "weak" — and excluded from averages, level counts and roadmaps.

SSL LABS — DISPLAY ONLY

Qualys grade shown alongside for cross-checking, but by design it never feeds the PQC score — one methodology, one number.

 Per-service scores aggregate to a domain score; the **worst observed configuration drives the findings.**



Drop an image

or [browse files](#)

